

Threat Modeling Process

1. *What are we working on?*

Understand/diagram your system (*or describe for an LLM)

2. *What could go wrong?*

Identify threats through answers to questions

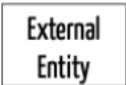
3. *What are we going to do about it?*

Determine mitigations and risks

4. *Did we do a good enough job?*

Review and follow through

Diagram - Data Flow Diagram (DFD) – Shapes and Examples

Notation element	Reference	Examples
	External entity	People (e.g., users), systems (e.g., other devices), cloud services, browsers
	Process	DDL, exe(D)COM, web service, virtual machine, threat
	Data store	File, database, registry, cache, cookie
	Data flow	http request or response, remote procedure call, UDP communication
	Trust boundary (inside you trust the processes and data stores, outside you don't)	Device boundary, process boundary

Identify threats - STRIDE – Definitions and Example Mitigations

Threat	Property Violated	Threat Definition	Threat Mitigations
Spoofing	Authentication	Pretending to be something or someone other than yourself	2FA, MFA, Another provider
Tampering	Integrity	Modifying something on disk, network, memory, or elsewhere	Crypto integrity, authorized users only
Repudiation	Non-Repudiation	Claiming you didn't do something or were not responsible can be honest or false	Maintain logs, digital signature
Information Disclosure	Confidentiality	Providing information to someone not authorized to access it	Data in files, logs, etc., available to authorized users only
Denial of Service	Availability	Exhausting resources needed to provide service	Rate-limiting, throttling access, and monitoring
Elevation of Privilege	Authorization	Allowing someone to do something they are not authorized to do	Central authorization, ACLs, limits on writing, roles/permissions

Mitigations and Risks - What are we going to do about it?

After identifying all possible threats, you can find ways to mitigate those threats.

In collaboration with the security expert, you will do the following:

- Cover all threats
- Identify controls that are already in place
- Handle threats that are not (completely) covered
 - Redesign to eliminate
 - Apply standard mitigations
 - Create new mitigations
 - Accept vulnerability in the design

Review and Follow Through - Did we do a good enough job?

This final stage is more on the reporting of a threat model and communication to other people:

- This is the most important step; action needs to be taken
- The (threat model) report works as a basis for discussion
 - Input for other security activities
 - Describes (accepted) residual risk
 - Input for the next iteration
- Update upon major changes in risk profile or software